

SIMATS ENGINEERING

ASSESSMENT TOOL 2 — Port Scanning Challenge

Course Name: Ethical Hacking	Course Code: ITA14
Name: PRANOV RAAJ	Reg No: 192372355
CO3: Analyze network services using port scanning, ping sweeps, and enumeration techniques across different operating systems to identify vulnerabilities. (BT4)	

Q1. Identifying and Prioritizing Vulnerabilities After a Port Scan

Once a port scan reveals multiple open ports, the raw list of ports is only a starting point. The goal is to convert that list into a prioritized, actionable set of findings. My approach follows these stages:

1. Service and Version Enumeration

For every open port, I run a service/version detection scan (Nmap -sV) and, where appropriate, OS fingerprinting (-O) and NSE scripts (--script vuln, --script default) to identify exactly what software and version is listening on each port. Knowing the precise product/version (e.g., OpenSSH 7.2, vsftpd 2.3.4) is essential because vulnerabilities are version-specific.

2. Vulnerability Correlation

Each identified service/version is checked against known-vulnerability databases such as the National Vulnerability Database (NVD), CVE Details, Exploit-DB, and Nmap's own vulnerability scripts. This maps each open port to a concrete list of CVEs, misconfigurations, or default-credential risks rather than a generic 'open port = risk' assumption.

3. Risk-Based Prioritization

Not every open port carries equal risk, so I prioritize using a combination of factors:

- **Exploitability** — is there a public, weaponized exploit (e.g., on Exploit-DB or Metasploit) for the CVE?
- **CVSS score** — higher base scores (especially those affecting confidentiality, integrity, and availability) are treated as more urgent.
- **Exposure** — services reachable from the internet or from untrusted network segments are prioritized above services only reachable internally.
- **Business criticality** — a vulnerable database or authentication service is ranked above a vulnerable low-impact service, since compromise there has a bigger blast radius.
- **Ease of exploitation** — unauthenticated remote code execution outranks a vulnerability that needs local access or valid credentials.

4. Validation Before Reporting

Before finalizing the list, I validate high-priority findings (banner grabbing, manual confirmation, or safe non-destructive PoC checks) to weed out false positives generated by version banners that don't reflect an actual patched vs unpatched state.

5. Documentation and Remediation Mapping

Finally, each vulnerability is logged with the affected host, port, service, CVE/CVSS reference, evidence, and a recommended remediation (patch, reconfiguration, network segmentation, or firewalling) so the results can be handed to the system owner as a prioritized action list rather than a raw scan dump.

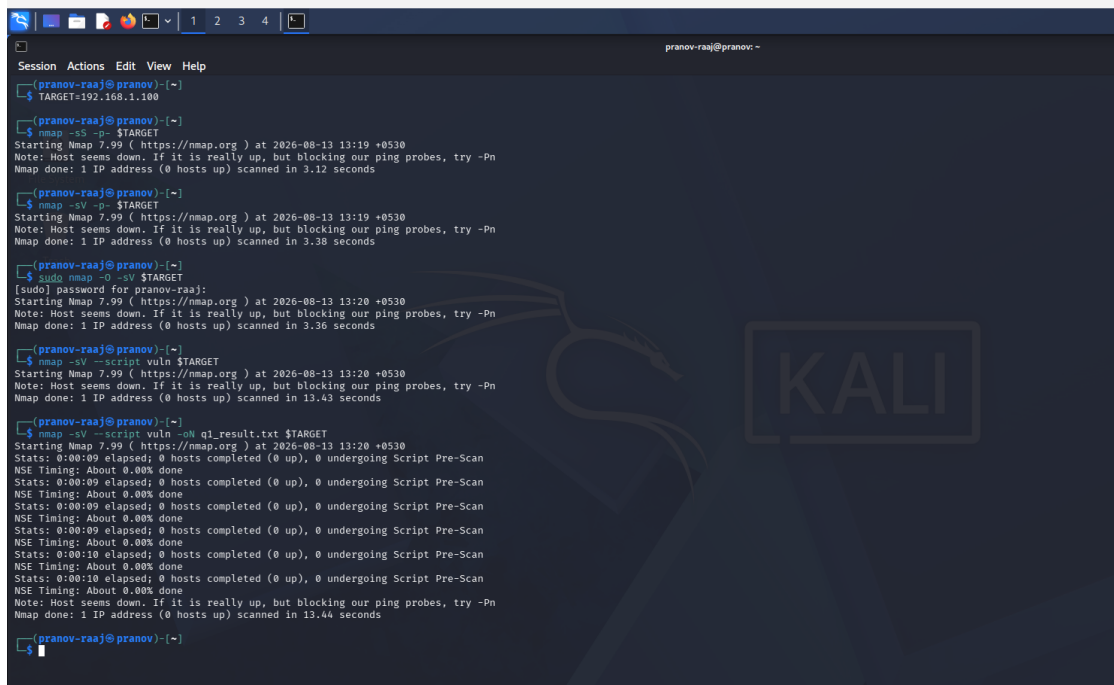


Fig 1: Nmap service/version and vulnerability scan (-sV --script vuln) with results saved to q1_result.txt for later triage.

Q2. SYN Scan vs TCP Connect Scan — Causes of Differing Results and Verification

A SYN scan (-sS) and a TCP Connect scan (-sT) both aim to discover the state of TCP ports, but they use different mechanisms, so it is common for them to report different results on the same target. Several factors can explain such discrepancies:

Possible Causes

- **Privilege level:** SYN scan requires raw-socket access (root/administrator) to craft custom packets, so if run without sufficient privileges Nmap silently falls back to a Connect scan, giving misleadingly 'identical' or incomplete results.
- **Firewall/IDS behaviour:** A stateful firewall may treat a full TCP handshake (Connect scan) differently from a lone SYN packet — some devices only log/block completed connections, letting SYN scans slip through, or vice versa.
- **Connection logging on the target:** Because a Connect scan completes the three-way handshake, it is logged by the target's application/OS, potentially triggering rate-limiting, connection resets, or IPS responses on subsequent probes — SYN scans, which never complete the handshake, are stealthier and less likely to trigger this behaviour, so they may see more ports as open.
- **Network conditions:** Packet loss, load balancers, or intermediate NAT/proxy devices can behave differently for half-open vs full connections, causing inconsistent RST/timeout responses between the two scan types.
- **Rate limiting/timeouts:** Different default timing templates (-T0 to -T5) between runs can cause ports to be reported as filtered in one scan and open in another simply due to timeout thresholds.

Verification Approach

- Re-run both scans with elevated privileges and identical timing templates (-T3) to remove privilege and timing as variables.
- Cross-check with a third technique, e.g., -sA (ACK scan) to test for firewall filtering, or a UDP/Connect combination, to see which result is consistent across methods.
- Use packet capture (Wireshark/tcpdump) alongside the scan to directly observe whether SYN-ACK, RST, or no response is being returned per port.

- Perform a manual connection test (e.g., telnet/nc to the port) to confirm ground truth for the specific ports in question.

```

pranov-raaj@pranov: ~
Session Actions Edit View Help
pranov-raaj@pranov: ~
$ TARGET=192.168.1.100
sudo nmap -sS -sV -p 1-1000 $TARGET
nmap -sT -sV -p 1-1000 $TARGET
[sudo] password for pranov-raaj:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 13:32 +0530
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 3.29 seconds
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 13:32 +0530
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 3.28 seconds
pranov-raaj@pranov: ~
$
  
```

Fig 2: Side-by-side SYN scan (`sudo nmap -sS -sV`) and TCP Connect scan (`nmap -sT -sV`) against the same target/port range to compare results.

Q3. Ports Reported as 'Filtered' — Causes and Further Techniques

When most scanned ports show up as 'filtered' rather than open or closed, it means Nmap could not determine the port's state because probe packets were dropped or no response was received. This is almost always caused by a security control sitting between the scanner and the target:

Likely Security Mechanisms

- Stateful firewalls / packet filters (iptables, Windows Firewall, pfSense) silently dropping unsolicited SYN or UDP packets instead of sending a RST.
- Network-based IDS/IPS actively blackholing scan traffic once it detects reconnaissance patterns.
- Router/ACL-level filtering at the network edge that blocks inbound traffic to specific port ranges.
- Host-based protections such as endpoint firewalls or security software configured to ignore/drop probes.
- Rate-limiting on ICMP or TCP RST generation, which can make open/closed ports look filtered under scan pressure.

Additional Techniques to Gather More Information

- Disable host discovery and force the scan through: use `-Pn` so Nmap doesn't skip a host it believes is 'down' due to blocked ping probes.
- Try alternate scan types: ACK scan (`-sA`) to map firewall rule sets, FIN/NULL/Xmas scans to see how the target's TCP stack reacts to unusual flag combinations, which some filters do not handle uniformly.
- Fragment packets (`-f`) or adjust MTU to try to slip past simple packet-inspection filters.
- Use decoy scanning (`-D`) or source-port manipulation (`--source-port 53`) to test whether the filter is trusting specific ports/sources.
- Slow the scan down (`-T1/-T2, --scan-delay`) to avoid triggering rate-based IDS/IPS blocking.

- Combine with UDP scanning (-sU) for services that may reply differently to UDP than TCP.
- Cross-reference with passive reconnaissance (banner grabbing, DNS, WHOIS, Shodan) so filtered TCP results can be supplemented with information gathered outside of active probing.

```

pranov-raaj@pranov: ~
$ TARGET=192.168.1.100
sudo nmap -Pn -sU --top-ports 20 $TARGET
[sudo] password for pranov-raaj:
Sorry, try again.
[sudo] password for pranov-raaj:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 13:59 +0530
Nmap scan report for 192.168.1.100
Host is up.

PORT      STATE      SERVICE
53/udp    open|filtered  domain
67/udp    open|filtered  dhcp
68/udp    open|filtered  dhcp
69/udp    open|filtered  tftp
123/udp   open|filtered  ntp
135/udp   open|filtered  msrpc
137/udp   open|filtered  netbios-ns
138/udp   open|filtered  netbios-dgm
139/udp   open|filtered  netbios-ssn
161/udp   open|filtered  snmp
162/udp   open|filtered  snmptrap
445/udp   open|filtered  microsoft-ds
500/udp   open|filtered  isakmp
514/udp   open|filtered  syslog
520/udp   open|filtered  route
631/udp   open|filtered  ipp
1434/udp  open|filtered  ms-sql-m
1900/udp  open|filtered  upnp
4500/udp  open|filtered  nat-t-ike
49152/udp open|filtered  unknown

Nmap done: 1 IP address (1 host up) scanned in 5.85 seconds
pranov-raaj@pranov: ~
$
  
```

Fig 3: UDP scan (`sudo nmap -Pn -sU --top-ports 20`) showing ports reported as open|filtered, requiring further techniques to disambiguate.

Q4. TCP vs UDP vs Stealth (SYN) Scanning — Comparison

TCP Connect, UDP, and SYN (stealth) scans each interact with the target's networking stack differently, which affects their accuracy, speed, and detectability.

Aspect	TCP Connect (-sT)	SYN / Stealth (-sS)	UDP (-sU)
Mechanism	Completes full 3-way TCP handshake	Sends SYN only, never completes handshake (half-open)	Sends UDP datagram; relies on response or ICMP unreachable
Speed	Slower — full handshake per port	Fast — no handshake completion	Slow — often needs retransmits and timeouts
Stealth	Low — logged by target OS/app as a full connection	Higher — many systems don't log incomplete handshakes	Moderate — depends on ICMP rate limiting
Privileges needed	None (any user)	Raw sockets — root/admin required	Raw sockets — root/admin required
Best used when	No raw-socket privileges available; accuracy over stealth	Need fast, quiet reconnaissance of TCP services	Auditing services like DNS, DHCP, SNMP, NTP, TFTP
Limitations	Easily logged/detected; slower on large ranges	Needs elevated privileges; some IDS still detect it	Slow, unreliable (no handshake); often shown as open filtered

When Each Is Most Effective

- TCP Connect scan: best in environments where the scanner cannot obtain raw-socket privileges (e.g., restricted user accounts), or when maximum accuracy of the TCP three-way handshake result is more important than stealth.
- SYN/stealth scan: the default choice for authorized penetration testing on TCP services — fast, reasonably accurate, and less likely to appear in application-level logs, making it ideal for large-range reconnaissance.
- UDP scan: necessary whenever UDP-based services (DNS, DHCP, SNMP, NTP, TFTP) are in scope, since TCP scans cannot reveal anything about them; it is slower and less definitive because UDP has no handshake to confirm state.

```

pranov-raaj@pranov: ~
$ TARGET=192.168.1.100
nmap -Pn -sT --top-ports 100 $TARGET
sudo nmap -Pn -sU --top-ports 100 $TARGET
sudo nmap -Pn -sS -sV --top-ports 1000 $TARGET
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 14:09 +0530
Nmap scan report for 192.168.1.100
Host is up.
All 100 scanned ports on 192.168.1.100 are in ignored states.
Not shown: 100 filtered tcp ports (no-response)

Nmap done: 1 IP address (1 host up) scanned in 21.62 seconds
[sudo] password for pranov-raaj:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 14:10 +0530
Nmap scan report for 192.168.1.100
Host is up.
All 100 scanned ports on 192.168.1.100 are in ignored states.
Not shown: 100 open/filtered udp ports (no-response)

Nmap done: 1 IP address (1 host up) scanned in 21.87 seconds
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 14:10 +0530
Nmap scan report for 192.168.1.100
Host is up.
All 1000 scanned ports on 192.168.1.100 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 202.46 seconds
pranov-raaj@pranov: ~
$

```

Fig 4: Comparative scans — TCP Connect, UDP, and SYN+version scans (-sT, -sU, -sS -sV) against the same host to illustrate differences in speed and results.

Q5. Risk Assessment and Mitigation for Exposed Critical Services (SSH, FTP, Database)

Discovering that services such as SSH, FTP, and a database port (e.g., MySQL/3306) are directly reachable from the internet during an authorized assessment is a high-priority finding, since these services are common initial-access and lateral-movement targets. My assessment and recommendations would proceed as follows:

Risk Assessment

- Determine exact exposure: confirm the service, version, and authentication mechanism in use for each port (banner grabbing, version scripts such as ftp-anon, ftp-syst, ssh2-enum-algos, mysql-info).
- Check for weak/default configurations: anonymous FTP access, password-only SSH authentication, default or weak database credentials, and outdated protocol versions (e.g., SSHv1, unencrypted FTP).
- Evaluate exploitability: cross-reference detected versions against known CVEs and check for public exploits or brute-force feasibility (no account lockout, no rate limiting).
- Assess business impact: a compromised database can expose or corrupt sensitive data; a compromised SSH/FTP endpoint can provide a foothold for lateral movement or full server takeover, so impact is rated as high for all three if they are internet-facing.

- Classify overall risk: combine likelihood (ease of exploitation, exposure, known CVEs) with impact (data sensitivity, system criticality) to assign each finding a risk rating (e.g., Critical/High/Medium).

Mitigation Recommendations

- Remove unnecessary internet exposure: place SSH, FTP, and database ports behind a VPN, bastion host, or jump server rather than exposing them directly; restrict access via firewall rules/allow-lists to known IP ranges.
- Harden authentication: enforce key-based SSH authentication (disable password login), disable anonymous FTP, replace FTP with SFTP/FTPS, and enforce strong, unique database credentials with least-privilege accounts.
- Patch and upgrade: update all services to current, supported versions to close known vulnerabilities identified during enumeration.
- Apply network segmentation: keep database servers on an internal-only network segment, never directly reachable from the internet, with access only via the application tier.
- Add monitoring and rate limiting: enable logging/alerting for authentication attempts, implement account lockout or fail2ban-style protections, and monitor for anomalous connection patterns.
- Follow up with re-testing: after remediation, re-scan the same ports/services to confirm the exposure has been closed or sufficiently restricted before closing out the finding.

```

pranov-raaj@pranov:~$ TARGET=192.168.1.100
nmap -sS -sV -p 21,22,3306 $TARGET
nmap -sV --script vuln -p 21,22,3306 $TARGET
nmap -sV --script ftp-anon,ftp-syst -p 21 $TARGET
nmap -sV --script ssh2-enum-algos -p 22 $TARGET
nmap -sV --script mysql-info -p 3306 $TARGET
[sudo] password for pranov-raaj:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 14:17 +0530
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 3.16 seconds
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 14:17 +0530
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 11.52 seconds
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 14:17 +0530
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 3.19 seconds
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 14:17 +0530
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 3.24 seconds
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 14:17 +0530
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 3.23 seconds
pranov-raaj@pranov:~$

```

Fig 5: Targeted service enumeration on exposed critical ports (21-FTP, 22-SSH, 3306-MySQL) using vulnerability and service-specific NSE scripts.

Code of Conduct

I PRANOV RAAJ (Reg No: 192372355) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: _____